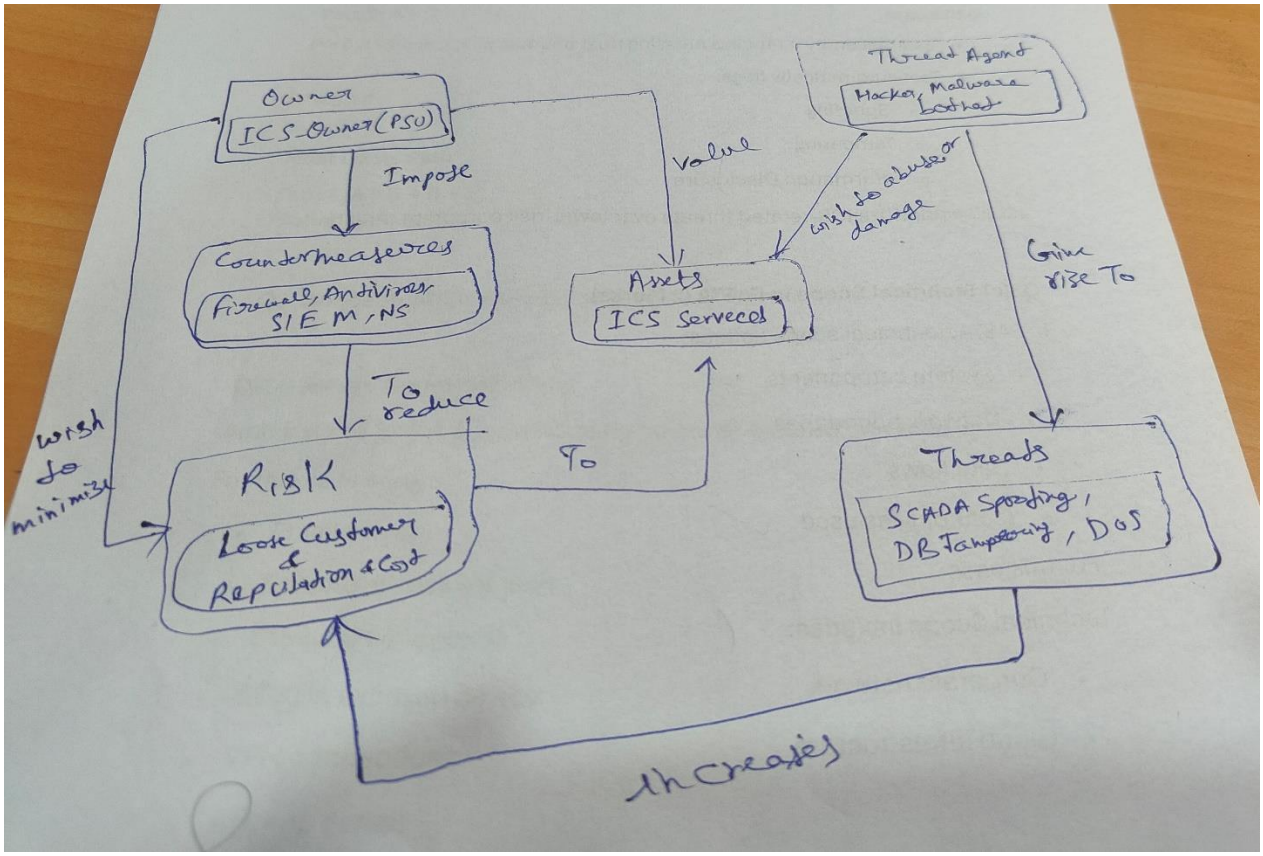
All solution needs proper justification as discussed in regular classes.

Q1(a) Identify & Classify 10 Critical Assets (4 Marks)

#	Asset	Asset Type	Violated Security Properties
1	Employee Workstation	Hardware	Integrity, Confidentiality
2	Email Server	Software/Service	Confidentiality
3	Cloud Services	Service	Availability
4	Backup Server	Hardware/Data	Integrity, Availability
5	SCADA System	Software/Hardware	Availability, Integrity
6	HMI	Software	Integrity
7	Vulnerable SCADA Device	Hardware	Integrity
8	Corporate Data	Data	Confidentiality
9	Remote User Credentials	Data	Authentication, Confidentiality
10	SIEM Logs	Data/Service	Accountability

Q1(b) Threat Modeling Ontology Instantiation (3 Marks)

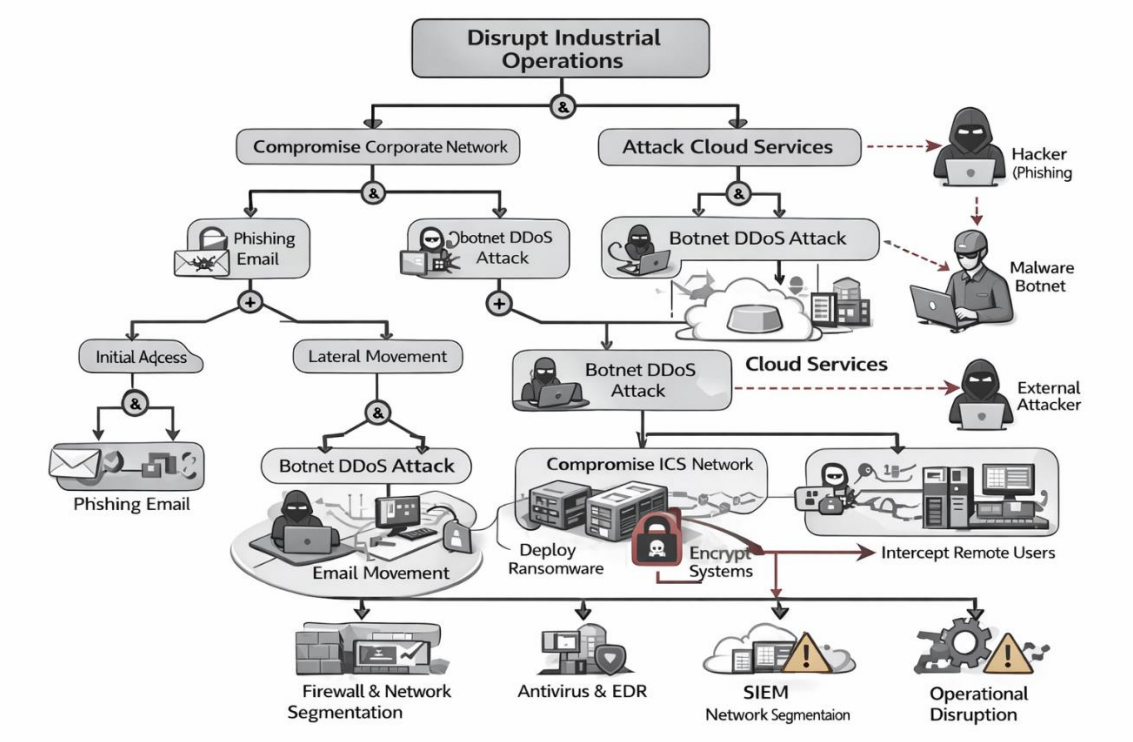


Q1(c) STRIDE Mapping Table (5 Marks)

Asset	Threat	STRIDE Category	Security Property Violated	Defense
Email Server	Phishing	Spoofing	Authentication	Email filtering + MFA
SCADA System	Ransomware	Tampering	Integrity	EDR + Backup isolation
Cloud Service	DDoS	Denial of Service	Availability	Rate limiting + CDN
Remote User Session	MitM	Information Disclosure	Confidentiality	TLS + VPN
Backup Server	Encryption	Tampering	Integrity	Immutable backups

Q1(d) Attack Tree (5 Marks)

Root Goal:Disrupt Industrial Operations



Q2. Attack Graph Probability (3 Marks)

Given Probabilities:

A → B = 0.6
B → D = 0.7
A → C = 0.4
C → D = 0.5
D → E = 0.9

Path 1: A → B → D → E

P = 0.378

Path 2: A → C → D → E

P = 0.18
Most Likely Path: Path 1 (A → B → D → E)
Probability = **0.378**

Q3(a) Attack Surface (1 Mark)

Attack surface = Total exposed entry points an attacker can exploit.

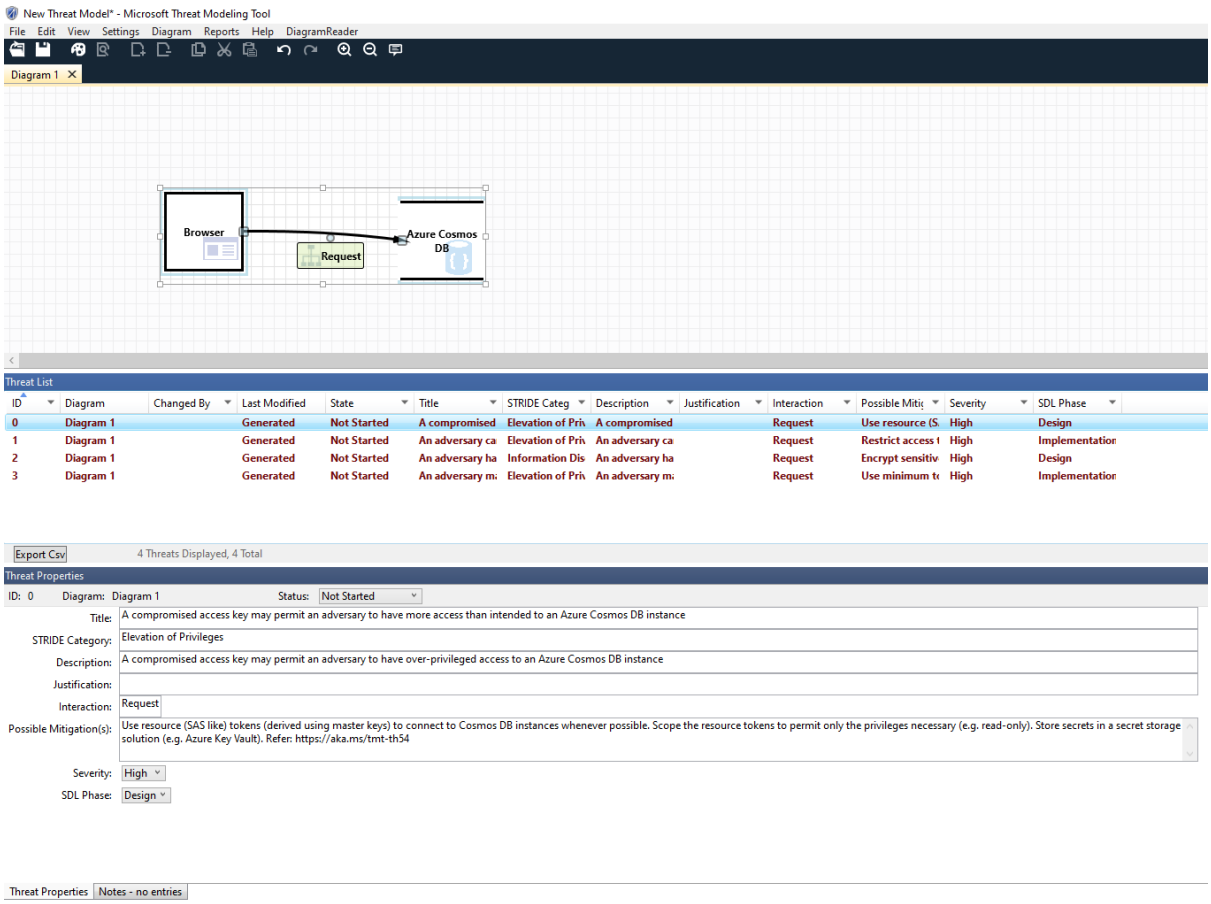
For this case study:

- Email server
- Remote access gateway
- Cloud API endpoints
- SCADA exposed device
- VPN connections
- Backup server
- Firewall misconfigurations

Large attack surface due to hybrid infrastructure + cloud + ICS integration.

Q3(b) Analysis View in Microsoft Threat Modeling Tool (2 Marks)

Explanation needs in terms following view, as discussed in classes.



Q3(c) Technical Scope in PASTA (2 Marks)

PASTA (Process for Attack Simulation and Threat Analysis) emphasizes business-aligned, risk-centric threat modeling. In this stage, the technical architecture and attack surface are formally scoped before threat enumeration.

System consists of three primary domains:

A. Corporate IT Network

- Workstations
- Email Server
- Internal user endpoints
- Backup Server
- Antivirus & EDR
- SIEM & Security Monitoring
- Firewall & Network Segmentation
- Access Control Systems

This zone serves as the initial compromise vector via phishing.

B. Cloud Infrastructure

- Cloud-hosted services
- Storage and application workloads
- Remote user VPN access
- Cloud-integrated backup storage

C. Operational Technology (OT) / ICS Environment

- SCADA / ICS Systems
- Human Machine Interface (HMI)
- Vulnerable SCADA device
- Industrial control servers

Trust Boundaries:

The architecture includes multiple trust zones:

1. Internet ↔ Corporate Network (Phishing, External Attacker Entry)
2. Internet ↔ Cloud Infrastructure (DDoS, Botnet Traffic)
3. Corporate IT ↔ Cloud Services (Hybrid connectivity)
4. Corporate IT ↔ OT Network (Segmentation boundary)
5. Remote Users ↔ Enterprise via VPN (MitM exposure)